

บทที่ 4

เอกสารสิทธิ์

4.1 ลักษณะของเอกสารสิทธิ์ดิจิทัล (Digital Certificate)

การรับรองและพิสูจน์ตนในการติดต่อสื่อสารนั้นเป็นสิ่งสำคัญอย่างยิ่ง เมื่อมีผู้ส่งข้อมูลมายังผู้รับ ผู้รับต้องตรวจสอบว่าผู้ส่งคือใครและสามารถเชื่อถือข้อมูลที่ส่งมาได้มากน้อยเพียงใด การรับรองและพิสูจน์ตนในการส่งข้อมูลแบบอิเล็กทรอนิกส์นั้นยังเป็นเรื่องที่ซับซ้อนเพราะเราไม่สามารถรู้ได้เลยว่าใครเป็นผู้ส่งที่แท้จริง เพราะสามารถทำการดักจับข้อมูลมาแก้ไขคัดแปลงเนื้อหาของข้อมูลได้ รวมถึงการแอบอ้างสิทธิ์ของผู้ส่งเอง

User Information
Name Sociality Card email address Birth day Public Key Issue Date Revocation Date
CA 's Private Key

Digital Ceritificate

รูปที่ 4.1 แสดงตัวอย่างของเอกสารสิทธิ์ที่ได้รับการรับรองจากองค์กรพิสูจน์สิทธิ์

เอกสารสิทธิ์เป็นเหมือนกับบัตรประจำตัวของบุคคลนั้น ซึ่งจะบ่งบอรายละเอียดของบุคคล เราสามารถส่งเอกสารสิทธิ์ไปพร้อมกับลายมือชื่อดิจิตอลเพื่อใช้ในการอ้างถึงผู้ส่ง การสร้างเอกสารสิทธิ์ทำโดยผู้ใช้ทุกคนทำการขอเอกสารสิทธิ์กับองค์กรพิสูจน์สิทธิ์ (Certificate Authority) โดยการส่งคีย์สาธารณะและข้อมูลตามที่องค์กรพิสูจน์สิทธิ์นั้นกำหนดไปและทำการขอเอกสารสิทธิ์มา การติดต่อต้องทำการเป็นส่วนตัวหรือติดต่อผ่านระบบการพิสูจน์บุคคลที่ปลอดภัย เราสามารถกำหนดสิ่งที่จำเป็นในการสื่อสารดังต่อไปนี้

1. ผู้ใช้ทุกคนสามารถคำนวณหาชื่อและคีย์สาธารณะของเจ้าของเอกสารสิทธิ์ได้
2. ผู้ใช้ทุกคนสามารถตรวจสอบได้ว่าเอกสารสิทธิ์มาจากองค์กรพิสูจน์สิทธิ์จริง ๆ ไม่ได้ถูกปลอมแปลงมา

3. ผู้ใช้สามารถตรวจสอบได้ว่าเอกสารสิทธิ์นั้นหมดอายุหรือไม่
4. ผู้ที่สามารถสร้างและอัปเดตเอกสารสิทธิ์ได้มีเพียงองค์กรผู้ที่มีอำนาจในการรับรองสิทธิ์เท่านั้น

5. ผู้ใช้ทุกคนสามารถตรวจสอบเอกสารสิทธิ์ได้เป็นประจำ

4.2 ความสำคัญของเอกสารสิทธิ์ดิจิทัล

ในระบบการเข้ารหัสแบบคีย์ต่างนั้นเราจะต้องมีการสร้างทั้งคีย์ส่วนตัวและคีย์สาธารณะ ซึ่งโดยทั่วไปการสร้างคีย์จะทำโดยโปรแกรมที่จะใช้คีย์นั้น เช่น โปรแกรมเว็บเบราว์เซอร์หรือโปรแกรมติดต่ออิเล็กทรอนิกส์เมลล์ หลังจากการสร้างคีย์ทั้งสองเรียบร้อยแล้วการเก็บรักษาคีย์เป็นเรื่องที่สำคัญ เราจะต้องเก็บรักษาคีย์ส่วนตัวไว้ให้ดีอย่าให้ใครมาแอบเห็นหรือขโมยไปได้ จากนั้นจะเป็นการตัดสินใจว่าจะทำการแจกจ่ายคีย์สาธารณะของเราไปสู่ผู้อื่นด้วยวิธีใด เช่น อาจแจกคีย์โดยส่งอิเล็กทรอนิกส์เมลล์ไปให้เพื่อนหรือบุคคลที่ติดต่อกับเรา แต่วิธีนี้เราอาจส่งคีย์ไปให้ไม่ครบทุกคน และยังต้องเป็นภาระคอยจัดการส่งคีย์ให้กับบุคคลใหม่ ๆ ที่ต้องการติดต่อด้วย นอกจากนี้ยังไม่สามารถทำให้ผู้รับมั่นใจได้ว่าคีย์ที่ส่งไปให้มันเป็นคีย์ของเราจริง ๆ เนื่องจากอาจมีผู้อื่นแอบสร้างคีย์โดยใช้ชื่อเราและแอบอ้างส่งคีย์ดังกล่าวให้กับผู้อื่นเพื่อให้เข้าใจว่าเป็นคีย์ของเราได้

วิธีที่ดีกว่าและใช้อยู่ในปัจจุบันก็คือการใช้ระบบแจกจ่ายคีย์ที่เชื่อถือได้โดยจะมีองค์กรที่ทำหน้าที่เฉพาะเป็นองค์กรที่สาม (Third Party) ในการรับรองและระงับการรับรองคีย์ที่เรียกว่า องค์กรพิสูจน์สิทธิ์ (Certificate Authority - CA) โดยองค์กรพิสูจน์สิทธิ์นี้จะตรวจสอบคีย์สาธารณะของเราด้วยหลักฐานว่าคีย์นั้นเป็นของเราจริง ๆ พร้อมทั้งตรวจสอบข้อมูลส่วนตัวของเรา (ข้อมูลที่ตรวจสอบจะมากน้อยแค่ไหนขึ้นอยู่กับระดับชั้นของการรับรอง) เมื่อผู้อื่นได้รับคีย์ของเราก็สามารถที่จะตรวจสอบกับผู้ออกเอกสารสิทธิ์นี้ว่าคีย์ที่ได้รับเป็นของเราจริงหรือไม่ ซึ่งตัวเอกสารสิทธิ์นี้จะเปรียบเสมือนบัตรประชาชนดิจิทัลของเราที่ใช้บอกได้ว่าเราเป็นบุคคลที่แท้จริง ๆ ในระบบเครือข่ายหรือการส่งข้อมูลทางอิเล็กทรอนิกส์

ในปัจจุบันบริษัทหลัก ๆ ที่ออกเอกสารสิทธิ์ดิจิทัล (Digital Certificate) คือ บริษัท Verisign, Cyvertrust, Global Sign และ Nortel โดยในเอกสารสิทธิ์ดิจิทัลจะประกอบด้วยข้อมูลต่าง ๆ ดังนี้ ชื่อของผู้ถือเอกสารสิทธิ์ ชื่อของบริษัทที่ออกเอกสารสิทธิ์ คีย์สาธารณะของผู้ถือเอกสารสิทธิ์ วันหมดอายุของเอกสารสิทธิ์ (โดยทั่วไปจะกำหนดระยะเวลา 6 เดือนหรือหนึ่งปี) ระดับชั้นของเอกสารสิทธิ์ และเลขหมายของตัวเอกสารสิทธิ์ดิจิทัลนั่นเอง

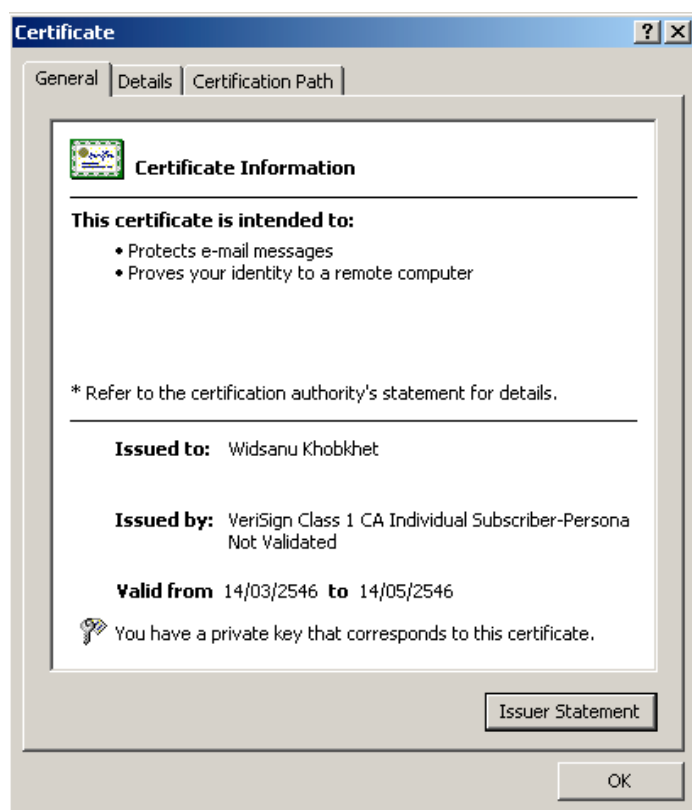
เอกสารสิทธิ์ดิจิทัลแบ่งออกได้เป็นสี่ระดับชั้นตามระดับการตรวจสอบข้อมูลของเจ้าของเอกสารสิทธิ์

1. ระดับชั้นที่หนึ่งเป็นชั้นที่ออกเอกสารสิทธิ์ได้ง่ายที่สุดเนื่องจากมีการตรวจสอบน้อยที่สุด โดยจะตรวจสอบแค่ชื่อผู้ถือเอกสารสิทธิ์ และที่อยู่อิเล็กทรอนิกส์เมลล์ (e-mail address) ว่าถูกต้องจริงเท่านั้น
2. ระดับชั้นที่สองจะตรวจสอบเลขประจำตัวประชาชน เลขประจำตัวของระบบสวัสดิการหรือประกันสังคม (Social Security Number) และวันเดือนปีเกิด
3. ระดับชั้นที่สามจะมีการตรวจสอบเพิ่มเติมเกี่ยวกับประวัติการใช้เครดิตและการชำระเงิน
4. ระดับชั้นที่สี่นั้นยังไม่มีการออกมาเป็นมาตรฐานอย่างแน่ชัด แต่จะเป็นการตรวจสอบข้อมูลเพิ่มเติมเกี่ยวกับตำแหน่งงานในองค์กรด้วย

ในการขอเอกสารสิทธิ์นั้นจะต้องกระทำการบนกระบวนการที่ปลอดภัย ซึ่งในปัจจุบันมี 2 วิธีคือ

1. การขอเอกสารสิทธิ์ผ่านโปรแกรมประเภทเบราว์เซอร์ เช่น อินเทอร์เน็ตเอ็กซ์พลอเรอร์, เนสเคปท์ เป็นต้น โดยผู้ใช้เข้าไปยังโฮสต์ที่ให้บริการการขอเอกสารสิทธิ์หรือเว็บไซต์ที่เปิดให้บริการดังกล่าวอยู่ ตัวโปรแกรมประเภทเบราว์เซอร์จะทำการสร้างคู่คีย์ คีย์ส่วนตัวจะเก็บไว้ที่เครื่องของเรา จากนั้นจะส่งคีย์สาธารณะและข้อมูลส่วนตัวของเราไปยังโฮสต์หรือไซต์ที่เป็นขององค์กรพิสูจน์ จากนั้นองค์กรพิสูจน์สิทธิ์จะทำการรับรองข้อมูลแล้วจึงส่งเอกสารสิทธิ์กลับมาที่เครื่องของเรา

2. การขอเอกสารสิทธิ์อีกรูปแบบหนึ่งคือการส่งเอกสารสิทธิ์ที่ไม่ผ่านระบบเครือข่าย กล่าวคือผู้ขอต้องไปทำการขอที่สำนักงานขององค์กรพิสูจน์สิทธิ์โดยตรง โดยทำเรื่องขอเอกสารสิทธิ์และกรอกข้อมูลส่วนตัว องค์กรพิสูจน์สิทธิ์จะทำการรับรองและบันทึกข้อมูลของผู้ขอแล้วทำการส่งเอกสารสิทธิ์พร้อมทั้งคีย์ส่วนตัวให้กับผู้ขอในรูปแบบของไฟล์ในแผ่นดิสก์ให้ผู้ขอนำไปบันทึกในเครื่องของตนเองต่อไป



รูปที่ 4.2 แสดงตัวอย่างเอกสารสิทธิ์ที่ได้รับจากองค์กรพิสูจน์สิทธิ์โดยใช้โปรแกรมประเภทเบราว์เซอร์

4.3 บริการพิสูจน์สิทธิ์แบบ X.509 (X.509 Authentication Service)

ระบบ X.509 เป็นระบบพิสูจน์สิทธิ์ที่สำคัญมากในระบบเครือข่าย โดย X.509 เป็นอนุกรมย่อยของ X.500 ซึ่งกำหนดมาตรฐาน ITU – T โดยขณะที่ X.500 เป็นตัวกำหนดโครงสร้างในลักษณะที่เป็นได

เรกทอรีหรือโครงสร้างนั้น X.509 จะทำหน้าที่ในการพิสูจน์สิทธิ์ให้กับส่วนต่าง ๆ ของไคลเอนต์นั้น สำหรับรูปแบบการใช้งานจะเน้นไปที่การพิสูจน์บุคคล เพื่อยืนยันการติดต่อเป็นสำคัญ

การทำงานของ X.509 จะมีโครงสร้างการทำงานที่เป็นไคลเอนต์โดยในที่นี้ไคลเอนต์จะทำหน้าที่เป็นที่เก็บข้อมูลที่ใช้ในการยืนยัน ซึ่งโดยทั่วไปจะอยู่ในรูปของเอกสารสิทธิ์ซึ่งในเอกสารสิทธิ์จะบรรจุคีย์สาธารณะของผู้ใช้ที่เข้ารหัสโดยคีย์ส่วนตัวขององค์กรที่จ่ายใบเอกสารสิทธิ์มาให้ สำหรับการทำงานของ X.509 นั้นจะมีขอบเขตการนำไปใช้งานที่กว้างขวางมาก เช่น ใช้ในการทำ Mail Security ใช้ในการทำ IP Security ใช้ในการทำ Web Security หรือหากจะกล่าวว่าเมื่อใดที่ต้องการพิสูจน์บุคคลหรือยืนยันเครื่องคอมพิวเตอร์แล้ว ก็มักจะอยู่ในขอบข่ายการทำงานของ X.509 เสมอ

X.509 ได้ถูกนำเสนอเมื่อปี 1988 จากนั้นได้ผ่านการปรับปรุงเป็นลำดับชั้น ในประเด็นต่าง ๆ รวมทั้งเรื่องความปลอดภัยด้วย จากนั้นก็ได้ออกมาเป็นข้อเสนอที่ปรับปรุงแล้วในปี 1993 และปรับปรุงอีกครั้งในปี 1995 โดยการทำงานของ X.509 จะใช้การเข้ารหัสแบบคีย์สาธารณะและใช้มาตรฐานลายมือชื่อดิจิตอลในการรับรองข้อมูล สำหรับอัลกอริทึมนั้นไม่ได้ระบุแน่นอนโดยสามารถเลือกใช้ได้หลายตัวแต่ที่แนะนำคืออาร์เอสเอ

รูปแบบทั่วไปของเอกสารสิทธิ์มีส่วนประกอบดังนี้

1. เวอร์ชัน (Version) แสดงหมายเลขเวอร์ชันเพราะในแต่ละเวอร์ชันจะมีรูปแบบของข้อมูลที่ไม่เหมือนกันก็ได้ โดยปกติจะเป็นเวอร์ชัน 1 แต่หากในเอกสารสิทธิ์มีการใช้
2. หมายเลขลำดับ (Serial Number) เป็นเลขจำนวนเต็ม โดยจะต้องไม่ซ้ำกันในองค์กรที่ออกเอกสารสิทธิ์ โดยเลขนี้จะเป็นเลขที่จะใช้อ้างถึงแต่ละเอกสารสิทธิ์ที่สร้างขึ้นมา
3. อัลกอริทึมที่ใช้สร้าง (Signature Algorithm Identifier) เป็นฟิลด์ที่ระบุอัลกอริทึมที่ใช้ในการสร้างเอกสารสิทธิ์
4. ชื่อผู้ออกเอกสารสิทธิ์ (Issue Name) เป็นชื่อขององค์กรที่ออกเอกสารสิทธิ์
5. ช่วงเวลาที่รับรองเอกสารสิทธิ์ (Period of Validity) เป็นตัวบอกว่าให้ใช้เอกสารสิทธิ์นี้ตั้งแต่วันที่เท่าไรและสิ้นสุดวันที่เท่าไร
6. ชื่อเจ้าของเอกสารสิทธิ์ (Subject Name) เป็นชื่อของบุคคลที่เอกสารสิทธิ์ใบนี้อ้างถึงหรือแทนตัวบุคคลนั้น
7. ข้อมูลของคีย์สาธารณะ (Subject's Public Key Information) เป็นฟิลด์ที่เก็บคีย์สาธารณะและระบุถึงอัลกอริทึมที่ใช้กับคีย์นี้ขึ้นมา รวมถึงพารามิเตอร์อื่น ๆ ด้วย
8. ตัวระบุผู้ออกเอกสารสิทธิ์ (Issuer Unique Identifier) เป็นฟิลด์ออปชันที่ใช้ในการระบุถึงองค์กรที่ออกเอกสารสิทธิ์ ในกรณีชื่อ X.500 มีการนำไปใช้กับส่วนอื่น ๆ
9. ตัวระบุผู้ขอเอกสารสิทธิ์ (Subject Unique Identifier) เป็นฟิลด์ที่ใช้ในการระบุถึงตัวบุคคลที่เป็นเจ้าของเอกสารสิทธิ์ ในกรณีชื่อ X.500 มีการนำไปใช้กับส่วนอื่น ๆ
10. ส่วนขยาย (Extension) เป็นกลุ่มของฟิลด์ที่เพิ่มเติมข้อมูลอื่น ๆ เข้ามาด้วย

11. ลายมือชื่อ (Signature) จะบรรจุเมสแซจไคเจสต์ของข้อมูลในทุกฟิลด์ที่เข้ารหัสด้วยคีย์ส่วนตัวขององค์กรพิสูจน์สิทธิ์เพื่อเป็นการยืนยันว่าเอกสารสิทธิ์นี้สร้างมาจากองค์กรดังกล่าว จริง ๆ โดยจะมีข้อมูลที่ระบุวิธีการแฮชและวิธีการเข้ารหัสด้วย

ในการใช้งานเอกสารสิทธิ์จะมีช่วงเวลาใช้งานที่จำกัดแน่นอน ดังนั้นหากผู้ใช้ต้องการใช้เอกสารสิทธิ์ต่อไปก็ต้องขอต่ออายุเอกสารสิทธิ์ก่อนที่จะหมดอายุ แต่หากมีการหมดอายุโดยที่ไม่ขอต่อหรือมีการเลิกใช้เอกสารสิทธิ์อาจจะเนื่องมาจากพนักงานลาออก หรืออาจจะเนื่องจากเอกสารสิทธิ์นี้ไม่ปลอดภัยแล้วก็ต้องทำการเรียกคืน (Revoke) และองค์กรพิสูจน์สิทธิ์จะต้องมีการจัดทำรายการเอกสารสิทธิ์ที่ถูกเรียกคืน (Certificate Revocation List – CRL) ซึ่งจะเก็บไว้ในไคลเรทอรีและรับรองโดยองค์กรพิสูจน์สิทธิ์ ซึ่งผู้ที่ต้องการตรวจสอบเอกสารสิทธิ์ว่าเป็นเอกสารสิทธิ์ที่ไม่ใช้งานแล้วหรือไม่ ก็ต้องขอรายการเอกสารสิทธิ์ที่ถูกเรียกคืนไปตรวจสอบ

และเนื่องจากเอกสารสิทธิ์ไม่สามารถปลอมได้ ดังนั้นการเก็บเอกสารสิทธิ์ไว้ที่องค์กรพิสูจน์สิทธิ์จึงไม่ต้องมีกลไกพิเศษมาป้องกันแต่อย่างใด กล่าวคือผู้ใช้คนใดที่เป็นสมาชิกขององค์กรพิสูจน์สิทธิ์ก็สามารถเข้าถึงเอกสารสิทธิ์ของผู้ใช้คนอื่น ๆ ได้ทุกคน โดยเอกสารสิทธิ์นี้จะเก็บอยู่ในไฟล์เพียงไฟล์เดียวที่มีขนาดเล็ก นอกจากจะสามารถขอเอกสารสิทธิ์จากองค์กรพิสูจน์สิทธิ์แล้วผู้ใช้อังยังสามารถส่งเอกสารสิทธิ์ไปให้ตนเองได้อีกด้วยโดยผ่านทางสื่อต่าง ๆ เช่น จดหมายอิเล็กทรอนิกส์, ส่งผ่านแผ่นดิสก์เก็ต เป็นต้น

อย่างไรก็ตามเนื่องจากระบบเครือข่ายในปัจจุบันมีขนาดใหญ่โดกว้างขวางมากและการติดต่อสื่อสารก็ไม่ได้มีลักษณะเฉพาะกลุ่มอีกแล้ว ดังนั้นการที่จะให้ผู้ใช้ทุกคนมาใช้เอกสารสิทธิ์ที่รับรองโดยองค์กรพิสูจน์สิทธิ์เดียวกันทั้งหมดก็อาจเป็นเรื่องยาก หากผู้ใช้ 2 คนใช้เอกสารสิทธิ์ที่รับรองจากองค์กรพิสูจน์สิทธิ์คนละแห่งก็จะไม่สามารถตรวจสอบเอกสารสิทธิ์ของอีกฝ่ายได้ว่าเป็นฉบับจริงหรือไม่ ซึ่งในกรณีเช่นนี้ก็จะอาจจะใช้วิธีสำเนาที่สาธารณะขององค์กรพิสูจน์สิทธิ์ของผู้ใช้อีกคนหนึ่งมาทำการตรวจสอบเองก็สามารถทำได้ เช่น กำหนดให้มี CA – A และ CA – B โดยให้บริการกับผู้ใช้ A และ B แต่เนื่องจากในครั้งแรกที่ A สำเนาที่สาธารณะของ CA – B มานั้นอาจเกิดการปลอมได้ เพราะสิ่งที่เรามีอยู่ก็คือที่สาธารณะของ CA – A ของเรา แต่เอกสารสิทธิ์ของ CA – B ซึ่งบรรจุที่สาธารณะของ CA – B นั้นจะรับรองการเข้ารหัสด้วยคีย์ส่วนตัวของ CA – B ทำให้เราไม่สามารถตรวจสอบว่าเอกสารสิทธิ์ที่ได้รับมานั้นเป็นฉบับที่ถูกต้องหรือไม่ ดังนั้นวิธีดังกล่าวจึงถือว่ามีความปลอดภัยไม่เพียงพอ

สำหรับอีกวิธีการอีกแบบ คือให้ CA – A เก็บเอกสารสิทธิ์ของ CA – B เอาไว้ด้วยและ CA – B ก็เก็บเอกสารสิทธิ์ของ CA – A เอาไว้เช่นกัน ด้วยวิธีนี้เราก็สามารถให้องค์กรพิสูจน์สิทธิ์ตรวจสอบเอกสารสิทธิ์ได้ไม่ว่าเอกสารสิทธิ์นั้นจะรับรองจาก CA – A หรือ CA – B ก็ตาม เช่น ผู้ใช้ A ต้องการตรวจสอบเอกสารสิทธิ์ที่รับรองจาก CA – A ก็สามารถทำได้เลยเพราะรู้ที่สาธารณะของ CA – A อยู่แล้วเนื่องจากเป็นสมาชิกของ CA – A และหากผู้ใช้ A ต้องการตรวจสอบเอกสารสิทธิ์ที่รับรองโดย CA – B ผู้ใช้ A ก็ขอเอกสารสิทธิ์ของ CA – B จาก CA – A โดยเอกสารสิทธิ์ดังกล่าวจะรับรองโดย CA – A ดังนั้นจึงแน่ใจได้ว่าเอกสารสิทธิ์ของ CA – B ที่ได้รับนั้นเป็นของจริงและที่สาธารณะของ CA – B ก็เป็นของจริง

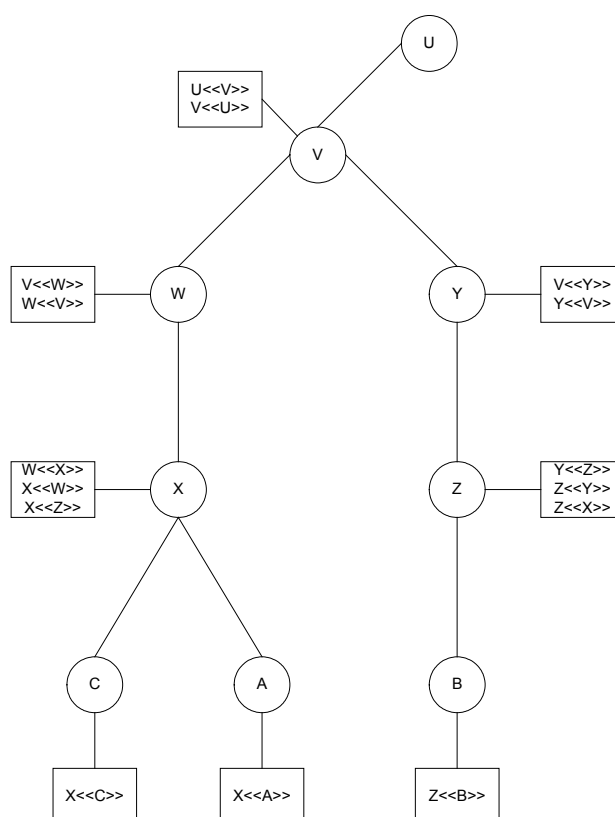
จากนั้นจึงนำเอาศิ่สาธารณะของ CA – B ไปตรวจสอบเอกสารสิทธิ์อีกทีก็จะทราบได้ว่าเอกสารสิทธิ์นั้นเป็นของจริงหรือไม่

และนอกเหนือจาก CA – A และ CA – B แล้วการเชื่อถือ (Trust) กันเช่นนี้ ยังสามารถกระทำกับองค์กรพิสูจน์สิทธิ์อื่น ๆ ไปเรื่อย ๆ อย่างไรก็ตาม หากองค์กรพิสูจน์สิทธิ์มีจำนวนมาก ๆ แล้ว ก็มีความจำเป็นที่จะต้องจัดโครงสร้างการเชื่อถือกันขององค์กรพิสูจน์สิทธิ์ให้เป็นระบบ ไม่เช่นนั้นก็อาจมีการเชื่อถือกันแบบยุ่งเหยิงและทำให้การทำงานเป็นไปอย่างไม่มีประสิทธิภาพได้ ซึ่งมาตรฐาน X.509 ก็ได้แนะนำให้มีการใช้ระบบเชื่อถือกันในรูปของความสัมพันธ์แบบระดับชั้น (Hierarchical) ซึ่งรูปที่ 4.3 จะแสดงความสัมพันธ์แบบระดับชั้นขององค์กรพิสูจน์สิทธิ์ต่าง ๆ โดยส่วนที่เป็นวงกลมจะหมายถึงความสัมพันธ์ระหว่างองค์กรพิสูจน์สิทธิ์ และในกล่องจะหมายถึงเอกสารสิทธิ์ที่เก็บไว้ในไคลเรทอรีของแต่ละองค์กรพิสูจน์สิทธิ์แบ่งออกเป็น 2 แบบ คือ

1. Forward Certificate หมายถึง เอกสารสิทธิ์ของ X ที่สร้างโดย CA อื่น ๆ
2. Reverse Certificate หมายถึง เอกสารสิทธิ์ที่สร้างโดย X ซึ่งก็จะกลายเป็นเอกสารสิทธิ์ขององค์กรพิสูจน์สิทธิ์อื่น ๆ ด้วย

จากตัวอย่างผู้ใช้ A ได้ขอเอกสารสิทธิ์จาก CA – B จะได้เส้นทางของเอกสารสิทธิ์ดังนี้

$X \ll W \gg W \ll V \gg V \ll Y \gg Y \ll Z \gg Z \ll B \gg$



รูปที่ 4.3 จะแสดงความสัมพันธ์แบบระดับชั้นขององค์กรพิสูจน์สิทธิ์ต่าง ๆ ตามรูปแบบ X.509